

Task 5 Policy Review Exercise

By **Stephen Reilly** | *Security Policy Analysis Series*

Objective

Conduct a comprehensive policy review and gap analysis against a compliance framework.

Scenario

You are a security consultant hired by **RetailMax Corporation** to assess their security policy program. The company is preparing for:

- PCI-DSS certification (they process credit cards)
- ISO 27001 certification
- SOC 2 Type II audit

They have provided you with their current policies (simulated below).

Current Policy Inventory

RetailMax has the following policies:

Policy	Status
Information Security Policy	Active (2019)
Password Policy	Active (2020)
Acceptable Use Policy	Active (2021)
Incident Response Policy	Missing
Data Classification Policy	Missing
Access Control Policy	Missing

Task Requirements

Part A: Gap Analysis

Create a gap analysis comparing current policies against PCI-DSS requirements.

Part B: Policy Maturity Assessment

Assess the maturity of existing policies using this scale:

Level	Description
0 - Non-existent	No policy exists
1 - Initial	Policy exists but ad-hoc
2 - Developing	Policy documented but not consistently followed
3 - Defined	Policy documented, communicated, and followed
4 - Managed	Policy monitored and measured
5 - Optimized	Policy continuously improved

Part C: Prioritized Recommendations

Create a prioritized list of recommendations:

Priority	Recommendation	Justification	Effort	Timeline
1	[Action]	[Why]	[H/M/L]	[Weeks]
2	[Action]	[Why]	[H/M/L]	[Weeks]
...	...	...	...	...

Part D: Implementation Roadmap

Create a 12-month implementation roadmap in 4 phases:

Deliverables

Create a document containing:

- 1. **Executive Summary** (1 page)
- 2. **Gap Analysis Table** (Part A)
- 3. **Maturity Assessment** (Part B)
- 4. **Prioritized Recommendations** (Part C)
- 5. **Implementation Roadmap** (Part D)

RetailMax Corporation — Security Policy Gap Analysis & Remediation Plan

Document Version: 1.0
Prepared By: Security Consultant
Date: June 22, 2026
Review Date: June 22, 2027
Classification: Confidential
Contact: security@retailmax.com

Executive Summary

RetailMax Corporation is pursuing PCI-DSS certification, ISO 27001 certification, and a SOC 2 Type II audit simultaneously — an ambitious but achievable goal with disciplined execution. Our assessment reveals significant gaps across all three frameworks, primarily stemming from missing foundational policies and aging existing ones.

Key Findings:

- **Three critical policies are entirely absent:** Incident Response, Data Classification, and Access Control — each of which maps to mandatory requirements across all three target frameworks.
- **Existing policies are outdated,** with the Information Security Policy dating back to 2019 — likely predating significant changes in RetailMax's threat landscape and technology stack.
- **Overall policy maturity averages Level 1 (Initial)** — policies exist in isolation without consistent enforcement, measurement, or continuous improvement.

- **No evidence of integrated policy governance** — no version control, review cadence, or ownership tracking was provided, suggesting an ad-hoc approach to policy lifecycle management.

Closing these gaps will require sustained effort across policy development, organizational change management, and technical controls. We recommend a phased 12-month approach that addresses the highest-risk deficiencies first while building toward a mature, auditable security program.

Part A: Gap Analysis — Current Policies vs. PCI-DSS Requirements

PCI-DSS Requirement	Description	Current Coverage	Gap Identified
Req 1	Install and maintain network security controls	Not addressed	Full Gap — No firewall/network security policy
Req 2	Apply secure configurations to all components	Partially covered by Info Sec Policy (2019)	Significant Gap — Likely outdated; no hardening standards
Req 3	Protect stored account data	Not addressed	Full Gap — No data classification or encryption policy
Req 4	Protect cardholder data during transmission	Not addressed	Full Gap — No cryptography or data-in-transit policy
Req 5	Protect against malicious software	Not addressed	Full Gap — No anti-malware or endpoint protection policy
Req 6	Develop and maintain secure systems and software	Not addressed	Full Gap — No SDLC or change management policy
Req 7	Restrict access to need-to-know	Not addressed	Full Gap — Access Control Policy missing
Req 8	Identify users and authenticate access	Partially covered by Password Policy (2020)	Significant Gap — Password policy alone insufficient; no MFA mandate
Req 9	Restrict physical access to cardholder data	Not addressed	Full Gap — No physical security policy
Req 10	Log and monitor all access	Not addressed	Full Gap — No logging/monitoring policy
Req 11	Test security of systems regularly	Not addressed	Full Gap — No vulnerability management or penetration testing policy
Req 12	Support information security with organizational policies	Partially covered	Significant Gap — Overarching policy outdated; missing incident response, risk assessment, security awareness

Summary: RetailMax meets approximately 5–10% of PCI-DSS requirements through existing policies. The three missing policies (Incident Response, Data Classification, Access Control) alone map to Requirements 3, 7, 8, 10, and 12.

Part B: Policy Maturity Assessment

Policy	Level	Justification
Information Security Policy (2019)	1 — Initial	Exists but is 7 years old with no evidence of review cycle. Likely lacks alignment with current infrastructure and threat landscape. Ad-hoc application suspected.
Password Policy (2020)	2 — Developing	Documented and somewhat specific, but likely not enforced through technical controls (no mention of automated password hygiene). No MFA integration documented.
Acceptable Use Policy (2021)	2 — Developing	Relatively recent and documented. May be communicated during onboarding, but no evidence of regular reaffirmation, monitoring, or consequence enforcement.
Incident Response Policy	0 — Non-existent	No policy exists. This is a critical gap for all three target frameworks.
Data Classification Policy	0 — Non-existent	No policy exists. Without classification, it's impossible to apply appropriate controls — particularly for PCI-DSS Req 3 and ISO 27001 Annex A.
Access Control Policy	0 — Non-existent	No policy exists. Fundamental to least privilege (PCI-DSS Req 7), SOC 2 CC6, and ISO 27001 A.9.
Overall Program Maturity: Level 1 (Initial) — Policies exist piecemeal but lack integration, enforcement mechanisms, regular review, and measurement. The program operates reactively rather than as a managed system.		

Part C: Prioritized Recommendations

Priority	Recommendation	Justification	Effort	Timeline
1	Draft and implement Incident Response Policy	Blocking requirement for all three frameworks; directly reduces business risk; PCI-DSS Req 12.10 mandates tested IR capability	H	4 weeks
2	Draft and implement Access Control Policy	Required by PCI-DSS Req 7–8, ISO 27001 A.9, SOC 2 CC6; foundational to least-privilege enforcement	H	4 weeks
3	Draft and implement Data Classification Policy	Enables appropriate controls for cardholder data (PCI-DSS Req 3); prerequisite for DLP and encryption strategies	M	3 weeks
4	Revise Information Security Policy (overhaul)	7-year-old policy is almost certainly misaligned; serves as the program's governing document	H	4 weeks
5	Update Password Policy to include MFA requirements	PCI-DSS Req 8.4 mandates MFA; current policy likely lacks this	L	2 weeks
6	Develop Network Security & Firewall Policy	PCI-DSS Req 1; define cardholder data environment boundaries	M	3 weeks

Priority	Recommendation	Justification	Effort	Timeline
7	Create Logging, Monitoring & Audit Trail Policy	PCI-DSS Req 10; SOC 2 CC7; enables detection and forensics	M	3 weeks
8	Establish Vulnerability Management Policy	PCI-DSS Req 11; mandates scanning and pen testing cadence	M	3 weeks
9	Formalize Acceptable Use Policy review/enforcement	Upgrade maturity from Level 2 → Level 3+; add monitoring and consequence framework	L	2 weeks
10	Implement Policy Governance Framework	Version control, review cadence (annual), owner assignment, approval workflow — required for ISO 27001 and SOC 2 documentation discipline	M	3 weeks
11	Develop Security Awareness Training Policy	PCI-DSS Req 12.6; ISO 27001 A.7; ensures workforce is a control, not a liability	M	3 weeks
12	Create Change Management & Secure SDLC Policy	PCI-DSS Req 6; reduces risk of insecure deployments	M	4 weeks

Part D: 12-Month Implementation Roadmap

Phase 1: Foundation (Months 1–3)

"Close the bleeding gaps — get the minimum viable policy program in place."

- **Month 1:** Draft and approve Incident Response Policy (Priority 1). Begin Access Control Policy drafting.
- **Month 2:** Finalize Access Control Policy (Priority 2). Begin Data Classification Policy and Information Security Policy overhaul.
- **Month 3:** Finalize Data Classification Policy (Priority 3). Complete Information Security Policy revision (Priority 4). Update Password Policy with MFA requirements (Priority 5).
- **Milestone:** All three missing policies enacted. Governing policy refreshed. MFA policy baseline established.

Phase 2: Expansion (Months 4–6)

"Build out the operational policies that enable detection and boundary defense."

- **Month 4:** Develop Network Security & Firewall Policy (Priority 6). Begin Logging & Monitoring Policy.
- **Month 5:** Finalize Logging, Monitoring & Audit Trail Policy (Priority 7). Begin Vulnerability Management Policy.
- **Month 6:** Finalize Vulnerability Management Policy (Priority 8). Conduct tabletop exercise testing the Incident Response Policy.
- **Milestone:** Core operational policies in place. First IR tabletop completed — evidence of policy testing for auditors.

Phase 3: Maturation (Months 7–9)

"Move from 'documented' to 'followed and measured' — target Level 3 maturity."

- **Month 7:** Implement Policy Governance Framework (Priority 10) — assign owners, set annual review dates, establish version control. Strengthen Acceptable Use Policy enforcement (Priority 9).
- **Month 8:** Launch Security Awareness Training Program (Priority 11). Begin internal audit of all Phase 1 policies for consistency and coverage.
- **Month 9:** Complete internal audit findings remediation. Begin developing metrics/KPIs for each policy area (e.g., IR response times, access review completion rates, training completion %).
- **Milestone:** Policies transition from Level 2 → Level 3 (Defined). Governance framework operational. Metrics collection begins.

Phase 4: Validation & Optimization (Months 10–12)

"Prove it works — prepare for formal audits and begin continuous improvement."

- **Month 10:** Create Change Management & Secure SDLC Policy (Priority 12). Conduct first formal internal compliance assessment against PCI-DSS self-assessment questionnaire.
- **Month 11:** Remediate internal assessment findings. Perform readiness review for ISO 27001 Stage 1 audit. Begin SOC 2 evidence collection and control testing.
- **Month 12:** Schedule external PCI-DSS assessment. Submit for ISO 27001 Stage 1. Initiate SOC 2 Type II observation period (if not already started). Establish continuous improvement feedback loop — target Level 4 maturity.
- **Milestone:** External audit readiness achieved. Continuous improvement cycle initiated. SOC 2 observation period underway.